

Vulnerabilities 101

Introduction to Vulnerabilities

weakness or flaw in the design, implementation or behaviours of a system or application

An attacker can exploit these weaknesses to gain access to unauthorised information or perform unauthorised actions

Vulnerability	Description
Operating System	These types of vulnerabilities are found within Operating Systems (OSs) and often result in privilege escalation.
(Mis)Configuration-based	These types of vulnerability stem from an incorrectly configured application or service. For example, a website exposing customer details.
Weak or Default Credentials	Applications and services that have an element of authentication will come with default credentials when installed. For example, an administrator dashboard may have the username and password of "admin". These are easy to guess by an attacker.
Application Logic	These vulnerabilities are a result of poorly designed applications. For example, poorly implemented authentication mechanisms that may result in an attacker being able to impersonate a user.
Human-Factor	Human-Factor vulnerabilities are vulnerabilities that leverage human behaviour. For example, phishing emails are designed to trick humans into believing they are legitimate.

Scoring Vulnerabilities (CVSS & VPR)

Common Vulnerability Scoring System

Vulnerability scoring serves a vital role in vulnerability management and is used to determine the potential risk and impact a vulnerability may have on a network or computer system

popular Common Vulnerability Scoring System (CVSS) awards points to a vulnerability based upon its features, availability, and reproducibility.

a score is essentially determined by some of the following factors (but many more):

- 1. How easy is it to exploit the vulnerability?
- 2. Do exploits exist for this?
- 3. How does this vulnerability interfere with the CIA triad?

use a [calculator \(opens in new tab\)](#) to figure out the score using this framework.

Rating	Score
None	0
Low	0.1 - 3.9
Medium	4.0 - 6.9
High	7.0 - 8.9
Critical	9.0 - 10.0

Advantages of CVSS	Disadvantages of CVSS
CVSS has been around for a long time.	CVSS was never designed to help prioritise vulnerabilities, instead, just assign a value of severity.
CVSS is popular in organisations.	CVSS heavily assesses vulnerabilities on an exploit being available. However, only 20% of all vulnerabilities have an exploit available (Tenable., 2020) .
CVSS is a free framework to adopt and recommended by organisations such as NIST.	Vulnerabilities rarely change scoring after assessment despite the fact that new developments such as exploits may be found.

Vulnerability Priority Rating

VPR scoring takes into account the relevancy of a vulnerability. For example, no risk is considered regarding a vulnerability if that vulnerability does not apply to the organisation (i.e. they do not use the software that is vulnerable)

Rating	Score
Low	0.0 - 3.9
Medium	4.0 - 6.9
High	7.0 - 8.9
Critical	9.0 - 10.0

Advantages of VPR	Disadvantages of VPR
VPR is a modern framework that is real-world.	VPR is not open-source like some other vulnerability management frameworks.
VPR considers over 150 factors when calculating risk.	VPR can only be adopted apart of a commercial platform.
VPR is risk-driven and used by organisations to help prioritise patching vulnerabilities.	VPR does not consider the CIA triad to the extent that CVSS does; meaning that risk to the confidentiality, integrity and availability of data does not play a large factor in scoring vulnerabilities when using VPR.
Scorings are not final and are very dynamic, meaning the priority a vulnerability should be given can change as the vulnerability ages.	<i>Intentionally left blank.</i>

Vulnerability Databases

1. [NVD \(National Vulnerability Database\)\(opens in new tab\)](#)
2. [Exploit-DB](#)

Term	Definition
Vulnerability	A vulnerability is defined as a weakness or flaw in the design, implementation or behaviours of a system or application.
Exploit	An exploit is something such as an action or behaviour that utilises a vulnerability on a system or application.
Proof of Concept (PoC)	A PoC is a technique or tool that often demonstrates the exploitation of a vulnerability.

NVD – National Vulnerability Database

The National Vulnerability Database is a website that lists all publically categorised vulnerabilities. In cybersecurity, vulnerabilities are classified under “Common Vulnerabilities and Exposures” (Or CVE for short).

These CVEs have the formatting of `CVE-YEAR-IDNUMBER` . For example, the vulnerability that the famous malware WannaCry used was `CVE-2017-0144`



VULNERABILITIES

August 2021

Below is a list of CVEs for the selected month.

NOTE: The CVEs shown below have a **release date** in the year and month chosen. The CVE ID may show a year value that does not match the release date, however, the release date will fall within the chosen year and month.

223 entries found for August 2021

CVE-2021-32066	CVE-2017-18113	CVE-2021-35477	CVE-2021-34556	CVE-2021-3351	CVE-2021-24371
CVE-2021-24425	CVE-2021-24428	CVE-2021-24430	CVE-2021-24443	CVE-2021-24444	CVE-2021-24448
CVE-2021-24450	CVE-2021-24455	CVE-2021-24456	CVE-2021-24457	CVE-2021-24458	CVE-2021-24459
CVE-2021-24460	CVE-2021-24461	CVE-2021-24462	CVE-2021-24463	CVE-2021-24464	CVE-2021-24468
CVE-2021-24470	CVE-2021-24472	CVE-2021-24473	CVE-2021-24474	CVE-2021-24476	CVE-2021-24477
CVE-2021-24478	CVE-2021-24479	CVE-2021-24480	CVE-2021-24481	CVE-2021-24483	CVE-2021-24484
CVE-2021-24488	CVE-2021-24492	CVE-2021-24496	CVE-2021-24498	CVE-2021-24503	CVE-2021-24504
CVE-2021-33526	CVE-2021-33527	CVE-2021-34574	CVE-2021-34575	CVE-2021-37165	CVE-2021-37216
CVE-2021-20332	CVE-2021-37160	CVE-2021-37161	CVE-2021-37162	CVE-2021-37163	CVE-2021-37164

Exploit-DB

[Exploit-DB\(opens in new tab\)](#) is a resource that we, as hackers, will find much more helpful during an assessment. Exploit-DB retains exploits for software and applications stored under the name, author and version of the software or application.

We can use Exploit-DB to look for snippets of code (known as Proof of Concepts) that are used to exploit a specific vulnerability.







☐ Verified
 ☐ Has App

Filters
 Reset All

Show 15
 Search:

Date	D	A	V	Title	Type	Platform	Author
2021-08-03				Hotel Management System 1.0 - Cross-Site Scripting (XSS) Arbitrary File Upload Remote Code Execution (RCE)	WebApps	PHP	Merbin Russel
2021-08-02				Panasonic Sanyo CCTV Network Camera 2.03-0x - 'Disable Authentication / Change Password' CSRF	WebApps	Hardware	LiquidWorm
2021-08-02				Online Hotel Reservation System 1.0 - 'Multiple' Cross-site scripting (XSS)	WebApps	PHP	Mohammad Koochaki
2021-08-02				Neo4j 3.4.18 - RMI based Remote Code Execution (RCE)	Remote	Java	Christopher Ellis
2021-08-02				Men Salon Management System 1.0 - SQL Injection Authentication Bypass	WebApps	PHP	Akshay Khanna
2021-07-29				Oracle Fatwire 6.3 - Multiple Vulnerabilities	WebApps	Multiple	J. Francisco Bolivar
2021-07-29				CloverDX 5.9.0 - Cross-Site Request Forgery (CSRF) to Remote Code Execution (RCE)	WebApps	Java	niebardzo
2021-07-29				Care2x Integrated Hospital Info System 2.7 - 'Multiple' SQL Injection	WebApps	PHP	securityforeveryone.com
2021-07-29				IntelliChoice eFORCE Software Suite 2.5.9 - Username Enumeration	WebApps	ASPX	LiquidWorm
2021-07-29				Longjing Technology BEMS API 1.21 - Remote Arbitrary File Download	WebApps	Hardware	LiquidWorm
2021-07-29				Denver IP Camera SHO-110 - Unauthenticated Snapshot	WebApps	Hardware	Ivan Nikolsky

An Example of Finding a Vulnerability

Applications and software usually have a version number. This information is usually left with good intentions; for example, the author can support multiple versions of the software and the likes. Or sometimes, left unintentionally.

For example, in the screenshot below, we can see that the name and version number of this application is “**Apache Tomcat 9.0.17**”

Apache Tomcat/9.0.17

If you're seeing this, you've successfully installed Tomcat. Congratulations!

**Recommended Reading:**

[Security Considerations How-To](#)
[Manager Application How-To](#)
[Clustering/Session Replication How-To](#)

[Server Status](#)
[Manager App](#)
[Host Manager](#)
Developer Quick Start
[Tomcat Setup](#)
[First Web Application](#)
[Realms & AAA](#)
[JDBC DataSources](#)
[Examples](#)
[Servlet Specifications](#)
[Tomcat Versions](#)
Managing Tomcat

For security, access to the [manager webapp](#) is restricted. Users are defined in:

\$CATALINA_HOME/conf/tomcat-users.xml

In Tomcat 9.0 access to the manager application is split between different users.
[Read more...](#)

[Release Notes](#)**[Changelog](#)****[Migration Guide](#)****[Security Notices](#)****Documentation****[Tomcat 9.0 Documentation](#)****[Tomcat 9.0 Configuration](#)****[Tomcat Wiki](#)**

Find additional important configuration information in:

\$CATALINA_HOME/RUNNING.txt

Developers may be interested in:

[Tomcat 9.0 Bug Database](#)

[Tomcat 9.0 JavaDocs](#)

[Tomcat 9.0 SVN Repository](#)

Getting Help**[FAQ and Mailing Lists](#)**

The following mailing lists are available:

[tomcat-announce](#)

Important announcements, releases, security vulnerability notifications. (Low volume).

[tomcat-users](#)

User support and discussion

[taglibs-user](#)

User support and discussion for [Apache Taglibs](#)

[tomcat-dev](#)

Development mailing list, including commit messages

With this information in hand, let's use the search filter on Exploit-DB to look for any exploits that may apply to **"Apache Tomcat 9.0.17"**.

☐ Verified
 ☐ Has App

Filters

Reset All

Show

15

Search:

Tomcat 9.0

Date	D	A	V	Title	Type	Platform	Author
2021-07-13			X	Apache Tomcat 9.0.0.M1 - Cross-Site Scripting (XSS)	WebApps	Multiple	Central InfoSec
2021-07-13			X	Apache Tomcat 9.0.0.M1 - Open Redirect	WebApps	Multiple	Central InfoSec
2020-01-08			X	Tomcat proprietaryEvaluate 9.0.0.M1 - Sandbox Escape	WebApps	Java	hantwister
2017-10-09			✓	Apache Tomcat < 9.0.1 (Beta) / < 8.5.23 / < 8.0.47 / < 7.0.8 - JSP Upload Bypass / Remote Code Execution (2)	WebApps	JSP	intx0x80
2017-09-20			X	Apache Tomcat < 9.0.1 (Beta) / < 8.5.23 / < 8.0.47 / < 7.0.8 - JSP Upload Bypass / Remote Code Execution (1)	WebApps	Windows	xxlegend

Showing 1 to 5 of 5 entries (filtered from 44,305 total entries)

FIRST

PREVIOUS

1

NEXT

LAST

Practical Task Showcase: Exploiting Ackme's Application



https://email.thepentestingco.thm/user/inbox



Folders

Inbox (10)

- Reports
- Training
- Support
- Junk (13)

Drafts

Sent

Trash

Messages

Kyle Hodgson

ACKme IT Services

13:32

ThatCloudCompany

Thank you for signing up!

11:46

Viewing

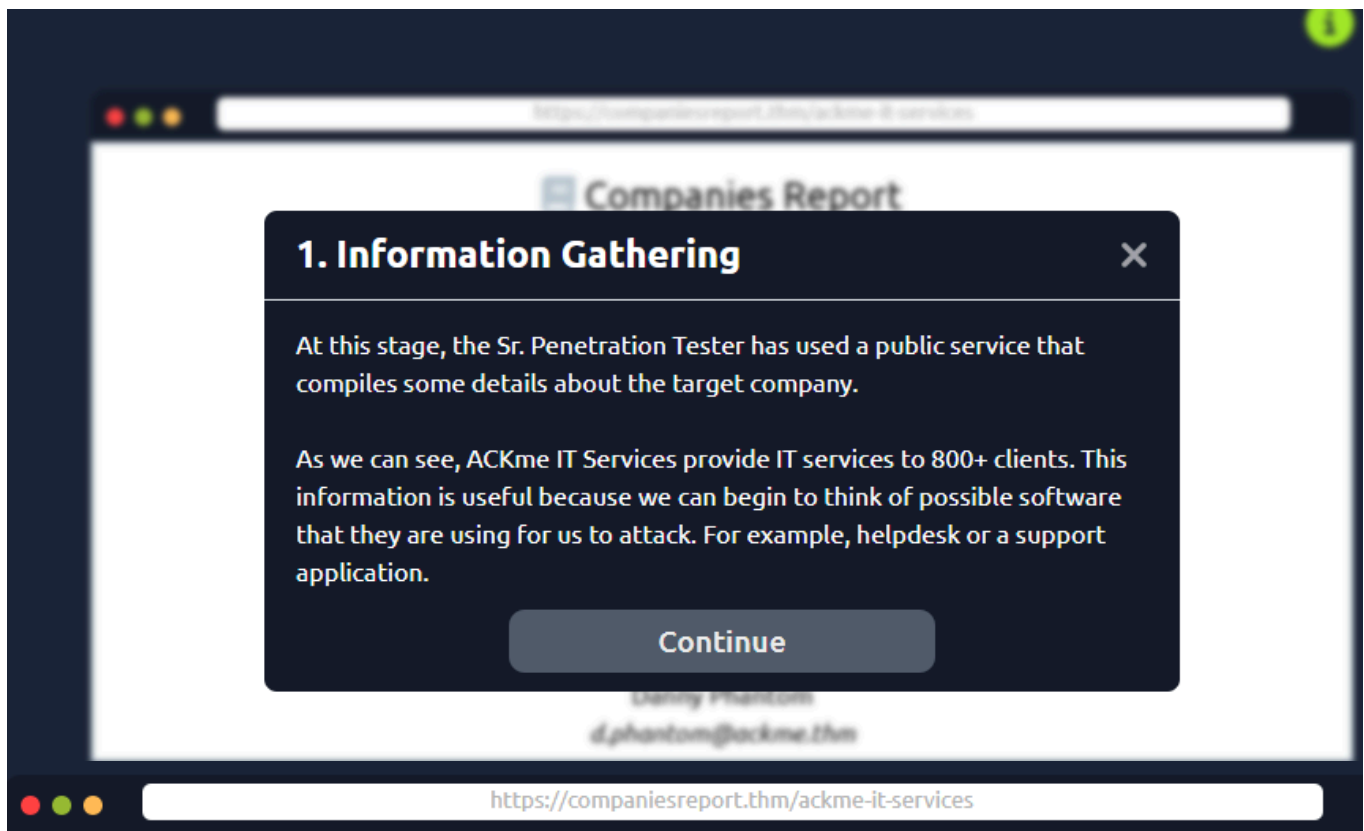
ACKme IT Services

From: Kyle Hodgson



Thank you for taking on this engagement. Please document every step extensively for the new Jr. Penetration tester to follow. I have attached our company reporting template to help with this. As a reminder, ACKme IT Services only want you to test the IP address **240.228.189.136**. Any other IP or machine is out of scope. Good luck!

Joe
Customer Liaison



Companies Report

Company Info

Established: 2017

Business Type: Corporation

Purpose: IT Support Services

Clients: 800+

CEO



Danny Phantom
d.phantom@ackme.thm

Enter IP Address

IP Address

2. Enumeration & Scanning



The Sr. Penetration tester now moves onto the enumeration and scanning stage of the engagement. This stage helps establish services and applications running on ACKme's infrastructure.

We can use the information gathered from this scan to begin to understand what services may be viable to attack. For example, a webserver hosting a website.

Recall from our Email, we are given one IP address **240.228.189.136**. Try scanning this IP address yourself...

Continue

```
user@thepentestingco:~$ nmap 240.228.189.136
```

```
Starting Nmap 7.60 ( https://nmap.org )
```

```
Nmap scan report for 240.228.189.136
```

```
Host is up (0.0013s latency).
```

```
Not shown: 997 closed ports
```

```
PORT STATE SERVICE
```

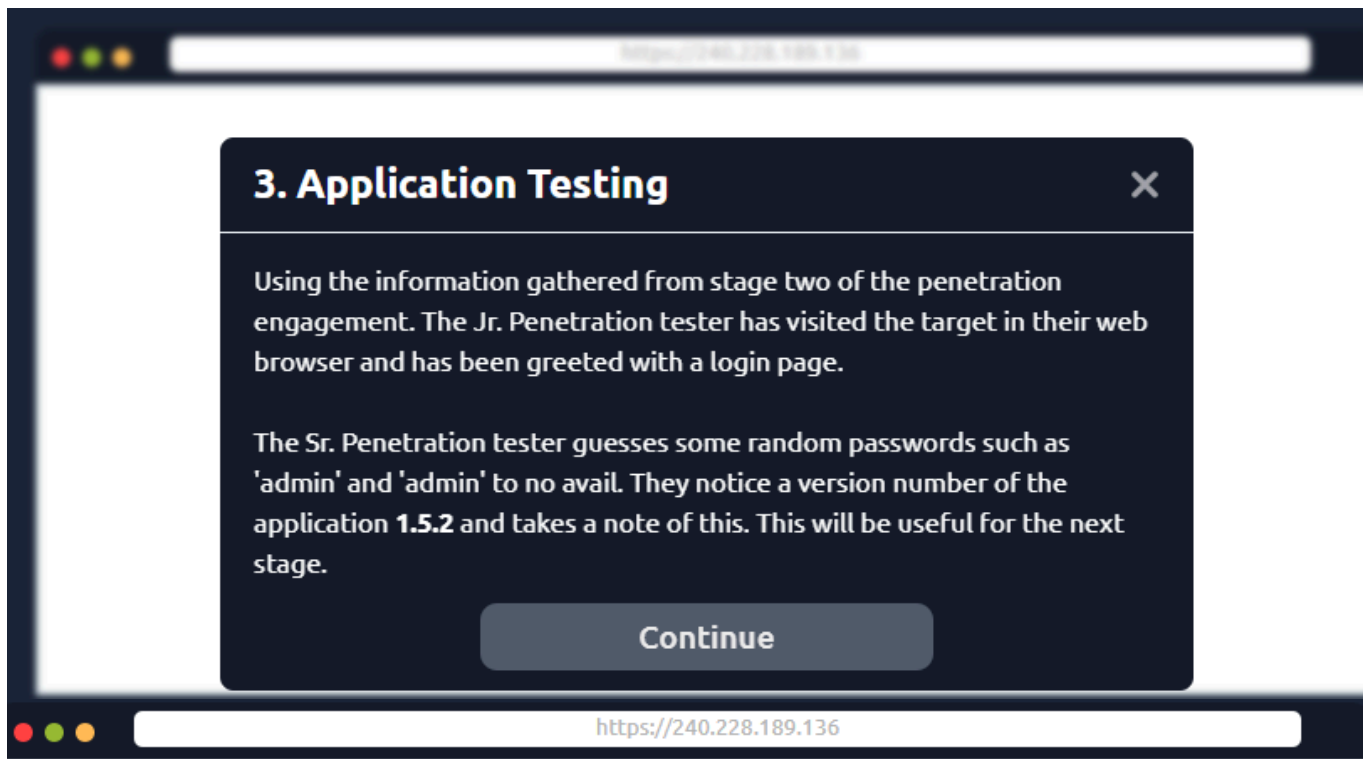
```
22/tcp open ssh
```

```
80/tcp open http
```

```
443/tcp open https
```

```
Nmap done: 1 IP address (1 host up) scanned in 8.35 seconds
```

```
user@thepentestingco:~$ nmap
```



ACKme Portal

Version 1.5.2

Username

Password

Log in

☐ Remember me [Forgot Password?](#)

4. Vulnerability Research



The Sr. Penetration tester recalls that ACKme IT Services uses an application called ACKme Portal that has a version number of 1.5.2. The Sr. Penetration Tester visits a vulnerability & exploit database called 'Vulnerability Bank™'.

This website stores details of vulnerabilities and exploits for applications. The Sr. Penetration Tester searches this site for the software that was discovered in stage three. They're in luck! There is one vulnerability listed for that application & version: Remote Code Execution (RCE).

RCE vulnerability allows commands to be executed on the target's system. The Sr. Penetration Tester could use this vulnerability to gain access to the console of the target. Try searching Vulnerability Bank™ for an exploit for **ACKMe Portal 1.5.2** and

Continue

